BREACHSIEVE - Vulnerability Assessment Report

Target: http://localhost:3000 | Date: 2026-10-17 15:44:40 UTC

Risk Score	Critical	High	Medium	Low	False Positives	Novel Patterns
9.9	**3**	**1**	**0**	**0**	**2**	**1**

Scope & Authorization Record

Target URL	http://localhost:3000
Scan Mode	ACTIVE (Active Confirmed: 1)
Authorization Status	CONFIRMED - Explicit authorization granted by operator
Authorized At	2026-10-17T15:43:26.061529+00:00
In-Scope Rules	localhost:3000 127.0.0.1
Out-of-Scope Rules	None

Confirmed Vulnerability Findings (4)

[BS-FIND-001] Missing Anti-clickjacking Header - **High (CVSS: 8.6)**

CWE: CWE-1021 | **OWASP:** A05:2021-Security Misconfiguration | **MITRE:** T1190
URL: http://localhost:3000
Description: The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.
Gemini AI Verdict: [CONFIRMED] Confirmed: HTTP response headers omit both 'X-Frame-Options' and CSP 'frame-ancestors'. The target page can be rendered inside an unauthorized <iframe> layer.
Remediation: Configure 'Content-Security-Policy: frame-ancestors self' and 'X-Frame-Options: SAMEORIGIN'.

[BS-FIND-002] X-Content-Type-Options Header Missing - **Critical (CVSS: 10.0)**

CWE: CWE-693 | **OWASP:** A05:2021-Security Misconfiguration | **MITRE:** T1562
URL: http://localhost:3000/favicon.svg
Description: The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.
Gemini AI Verdict: [CONFIRMED] The response returns 'HTTP/1.1 200 OK' with 'Content-Type: image/svg+xml', but completely lacks the 'X-Content-Type-Options: nosniff' header. Without this header, browsers may attempt MIME-sniffing, which can introduce security risks, particularly with XML/SVG documents.
Remediation: Configure the web server or reverse proxy to include 'X-Content-Type-Options: nosniff' on all HTTP responses, including static files.

[BS-FIND-003] Content Security Policy (CSP) Header Not Set - **Critical (CVSS: 10.0)**

CWE: CWE-693 | **OWASP:** A05:2021-Security Misconfiguration | **MITRE:** T1562
URL: http://localhost:3000
Description: Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
Gemini AI Verdict: [CONFIRMED] The response returns an HTML document as indicated by "Content-Type: text/html" and the body starting with "<!doctype html>". A review of the response headers confirms the complete absence of a 'Content-Security-Policy' header (the headers only include "Vary: Origin", "Content-Type: text/html", "Cache-Control: no-cache", "Etag: W/\"277-eOaHXd5eVjSF6Q6vUDl8nayX7Rs\"", "Date: Sat, 17 Oct 2026 15:43:27 GMT", "Connection: keep-alive", "Keep-Alive: timeout=5", and "Content-Length: 631"). Additionally, no `<meta http-equiv="Content-Security-Policy">` element is configured inside the `<head>` tag.
Remediation: Configure a strong 'Content-Security-Policy' HTTP response header (or meta tag) defining authorized sources for scripts, styles, images, and other resources to mitigate Cross-Site Scripting (XSS) and data injection attacks.

[BS-FIND-006] HTTP Only Site - **Critical (CVSS: 10.0)**

CWE: CWE-311 | **OWASP:** A05:2021-Security Misconfiguration | **MITRE:** T1190
URL: http://localhost:3000
Description: The site is only served under HTTP and not HTTPS.
Gemini AI Verdict: [CONFIRMED] The scanner attempted to establish a secure connection using 'GET https://localhost:3000 HTTP/1.1', but received 'HTTP/1.0 0', indicating a failed TLS handshake or connection reset. This confirms that the service on 'http://localhost:3000' is an HTTP-only site lacking transport layer encryption (CWE-311).
Remediation: Enable TLS encryption for the application and configure automatic redirection from HTTP to HTTPS with the HTTP Strict Transport Security (HSTS) header enabled.

Remediation Summary Matrix

ID	Title	Severity	Actionable Fix
BS-FIND-001	Missing Anti-clickjacking Head	High	Configure 'Content-Security-Policy: frame-ancestors self' and 'X-Frame-Options: SAME
BS-FIND-002	X-Content-Type-Options Header	Critical	Configure the web server or reverse proxy to include 'X-Content-Type-Options: nosniff'
BS-FIND-003	Content Security Policy (CSP)	Critical	Configure a strong 'Content-Security-Policy' HTTP response header (or meta tag) defini
BS-FIND-006	HTTP Only Site	Critical	Enable TLS encryption for the application and configure automatic redirection from HTT

Methodology Note

This assessment was performed using automated OWASP ZAP scanning driven through its REST API, restricted to strictly verified in-scope allow-list rules. Alerts were triaged via Google Gemini API using evidence-based analysis to filter false positives and identify novel patterns. This automated assessment augments, not replaces, comprehensive manual security testing.